Security Evaluation of LLM generated code

Mandatory questions are marked with a star (*)

Survey Statement

We are conducting this survey as part of a study on evaluating a security mechanism (for inclusivity) generated using Large Language Models (LLMs) as a joint research project between LUT University in Finland and RHUL, University of London. The following questions guide the research.

Effectiveness: How effectively can LLMs generate code that implements security and inclusivity requirements, particularly for neurodivergent users?

Influencing Factors: What factors (e.g., prompt design, model choice, and specification level) influence the quality of LLM-generated code with respect to security and inclusivity?

Evaluation: How does LLM-generated code perform when reviewed by humans and LLMs in terms of identifying security vulnerabilities and inclusivity gaps?

The study included six cases across two user studies, with prompts varying from minimal to highly detailed inclusivity specifications; however, static security requirements were specified across all cases.

Please evaluate the code from each case for security. The survey will take approximately 30 minutes to complete.

We sincerely appreciate your time and participation.

Please note that no personally identifiable information will be collected during this survey.

Participation consent *

☐ I agree to participate in the survey

Current role

Number of years of experience

User Story I:
Helena is a 67-year-old patient with chronic heart disease and a cognitive condition, ADHD. She calls the hospital to book an appointment to review her medication dosage. Due to updated security and privacy terms and conditions, she has to accept the updated conditions by logging in to her user account first, for hospital authorities to be able to book an appointment for her. The authentication to her personal healthcare account requires a strong password, which she has forgotten; therefore, she needs to reset the password to be able to access the account and accept the updated security and privacy terms and conditions.

Case I: No inclusivity specification
All references to any cognitive condition are removed. Baseline for the LLM's default behaviour.

Please access the code here: https://github.com/LLM4Code-inclusivitysecurity/securityevaluation/blob/main/story1_password_recovery_ADHD__case1_no_spec.ts

Security Evaluation criteria

Scale (1-5)
1: Strongly disagree, 2: Disagree, 3: Neutral, 4: Agree, 5: Strongly Agree

A01:2025 *

	1	2	3	4	5
The system checks that the reset code belongs to the account owner making the request *	○	○	○	○	○
Each reset code only works for its own account and cannot be used to access any other user's account. *	○	○	○	○	○
Previous sessions get terminated when the user resets their password. *	○	○	○	○	○

A02:2025 *

	1	2	3	4	5
Private information, tokens, and secret codes are never shown in error pages or logs. *	○	○	○	○	○
Passwords and secret codes are stored securely and are not hard coded anywhere. *	○	○	○	○	○
The system has no default or built in credentials. *	○	○	○	○	○

A04:2025 *

	1	2	3	4	5
The website uses HTTPS for all traffic with the latest TLS version. *	○	○	○	○	○
All reset codes and stored user data are protected using strong encryption and/or hashing. *	○	○	○	○	○
All reset codes and secrets are generated using secure random methods. *	○	○	○	○	○

A05:2025 *

	1	2	3	4	5
The code validates and sanitizes user input like email addresses and passwords. *	○	○	○	○	○
All redirect links are safe and stay within the hospital's own site. *	○	○	○	○	○
Email templates are safe and contain no script or HTML taken from user text *	○	○	○	○	○

A07:2025 *

	1	2	3	4	5
The system prevents repeated unsuccessful login attempts. *	○	○	○	○	○
The application does not reveal whether a username or email address exists. *	○	○	○	○	○
The reset code is random, difficult to guess, single use, and specific to the user. *	○	○	○	○	○

User Story I

Case II: Moderate Inclusivity Specification and Same Security Criteria

The patient has ADHD, as mentioned in the original user story, and was added.

Please access the code here: https://github.com/LLM4Code-inclusivitysecurity/securityevaluation/blob/main/story1_password_recovery_ADHD__case2_condition_named.t

Security Evaluation criteria

Scale (1-5)
1: Strongly disagree, 2: Disagree, 3: Neutral, 4: Agree, 5: Strongly Agree

A01:2025 *

	1	2	3	4	5
The system checks that the reset code belongs to the account owner making the request *	○	○	○	○	○
Each reset code only works for its own account and cannot be used to access any other user's account. *	○	○	○	○	○
Previous sessions get terminated when the user resets their password. *	○	○	○	○	○

A02:2025 *

	1	2	3	4	5
Private information, tokens, and secret codes are never shown in error pages or logs. *	○	○	○	○	○
Passwords and secret codes are stored securely and are not hard coded anywhere. *	○	○	○	○	○
The system has no default or built in credentials. *	○	○	○	○	○

A04:2025 *

	1	2	3	4	5
The website uses HTTPS for all traffic with the latest TLS version. *	○	○	○	○	○
All reset codes and stored user data are protected using strong encryption and/or hashing. *	○	○	○	○	○

	1	2	3	4	5
All reset codes and secrets are generated using secure random methods. *	○	○	○	○	○

A05:2025 *

	1	2	3	4	5
The code validates and sanitizes user input like email addresses and passwords. *	○	○	○	○	○
All redirect links are safe and stay within the hospital's own site. *	○	○	○	○	○
Email templates are safe and contain no script or HTML taken from user text *	○	○	○	○	○

A07:2025 *

	1	2	3	4	5
The system prevents repeated unsuccessful login attempts. *	○	○	○	○	○
The application does not reveal whether a username or email address exists. *	○	○	○	○	○
The reset code is random, difficult to guess, single use, and specific to the user. *	○	○	○	○	○

User Story I

Case III: Detailed Inclusivity Specification and Same Security Criteria

The following details, in addition to what was previously specified, were added: Description of the cognitive condition: People with ADHD can lose track of multi-step tasks, get easily distracted, and feel overwhelmed by unclear instructions or time pressure. The login and password reset flow must be forgiving, clear, and low-stress. Avoid dense instructions, timeouts, or unexpected page changes. Support memory and focus by showing visible progress and offering reminders of the next step.

Additional requirements:

- Keep the process simple and structured with clear, step-by-step guidance.
- Use straightforward and consistent language without unnecessary information.
- Provide clear feedback at each step so the user knows what has happened and what to do next.
- Allow enough time for actions without rushing or session timeouts.

• Reduce visual and cognitive distractions in the interface.
• Ensure the user can pause and return to the task without losing progress.
• Make help options easy to find and access at any stage.

Please access the code here: https://github.com/LLM4Code-inclusivitysecurity/securityevaluation/blob/main/story1_password_recovery_ADHD__case3_detailed_guidance.

Security Evaluation criteria

Scale (1-5)
1: Strongly disagree, 2: Disagree, 3: Neutral, 4: Agree, 5: Strongly Agree

A01:2025 *

	1	2	3	4	5
The system checks that the reset code belongs to the account owner making the request *	○	○	○	○	○
Each reset code only works for its own account and cannot be used to access any other user's account. *	○	○	○	○	○
Previous sessions get terminated when the user resets their password. *	○	○	○	○	○

A02:2025 *

	1	2	3	4	5
Private information, tokens, and secret codes are never shown in error pages or logs. *	○	○	○	○	○
Passwords and secret codes are stored securely and are not hard coded anywhere. *	○	○	○	○	○
The system has no default or built in credentials. *	○	○	○	○	○

A04:2025 *

	1	2	3	4	5
The website uses HTTPS for all traffic with the latest TLS version. *	○	○	○	○	○

	1	2	3	4	5
All reset codes and stored user data are protected using strong encryption and/or hashing. *	○	○	○	○	○
All reset codes and secrets are generated using secure random methods. *	○	○	○	○	○

A05:2025 *

	1	2	3	4	5
The code validates and sanitizes user input like email addresses and passwords. *	○	○	○	○	○
All redirect links are safe and stay within the hospital's own site. *	○	○	○	○	○
Email templates are safe and contain no script or HTML taken from user text *	○	○	○	○	○

A07:2025 *

	1	2	3	4	5
The system prevents repeated unsuccessful login attempts. *	○	○	○	○	○
The application does not reveal whether a username or email address exists. *	○	○	○	○	○
The reset code is random, difficult to guess, single use, and specific to the user. *	○	○	○	○	○

User Story II

Marcus is a 54-year-old self-employed contractor who has just opened an account with an online bank. He manages his account through the bank's mobile web application, a responsive website he opens in his phone's browser. Following a regulatory update, the bank requires all customers to enrol in multi-factor authentication (MFA) before authorising payments above a threshold. Marcus signs in, verifies his identity, sets up a time-based one-time passcode (OTP) authenticator, and securely stores a set of backup recovery codes. Marcus has dyslexia.

Case I: No Inclusivity Specification

All references to any cognitive condition are removed. Baseline for the LLM's default behaviour.

Please access the code here: https://github.com/LLM4Code-inclusivitysecurity/securityevaluation/blob/main/story2_mfa_enrolment_dyslexia__case1_no_spec.ts

Security Evaluation criteria

Scale (1-5)
1: Strongly disagree, 2: Disagree, 3: Neutral, 4: Agree, 5: Strongly Agree

A01:2025 *

	1	2	3	4	5
The system verifies that the MFA setup or code belongs to the account of the logged in user. *	○	○	○	○	○
A verification or backup code can be used only with the account for which it was issued. *	○	○	○	○	○
MFA and backup codes can only be set up through the bank's own pages, not through hidden requests from another website. *	○	○	○	○	○

A02:2025 *

	1	2	3	4	5
Secret keys, one-time codes, backup codes, and login tokens never appear in logs, links, or error pages. *	○	○	○	○	○
The site uses secure browser settings, such as secure cookies and protections against framing or reuse by other sites. *	○	○	○	○	○
The app only accepts requests from trusted sites, has no default passwords, and hides technical error details. *	○	○	○	○	○

A04:2025 *

	1	2	3	4	5
The website always uses HTTPS with a secure, up-to-date connection. *	○	○	○	○	○
The system securely generates and protects MFA secrets and backup codes. *	○	○	○	○	○
Login tokens and secret codes are not stored in the phone browser where they could be accessed. *	○	○	○	○	○

A05:2025 *

	1	2	3	4	5
The app sanitizes user input, including emails, phone numbers, and codes, before using it. *	○	○	○	○	○
Any links provided by the application keep users within the bank's own site. *	○	○	○	○	○
User text is safely displayed and cannot run hidden scripts or code. *	○	○	○	○	○

A07:2025 *

	1	2	3	4	5
The system blocks further attempts by the user after several incorrect codes. *	○	○	○	○	○
The application does not reveal whether an email address or account exists. *	○	○	○	○	○
Each verification or backup code is random, hard to guess, one-time, and expires quickly. *	○	○	○	○	○

User Story II

Case II: Moderate Inclusivity Specification and Same Security Criteria

The base scenario is used as written; "Marcus has dyslexia" is included, but no further detail about dyslexia or its implications is added.

Please access the code here: https://github.com/LLM4Code-inclusivitysecurity/securityevaluation/blob/main/story2_mfa_enrolment_dyslexia__case2_condition_named.ts

Security Evaluation criteria

Scale (1-5)
1: Strongly disagree, 2: Disagree, 3: Neutral, 4: Agree, 5: Strongly Agree

A01:2025 *

	1	2	3	4	5
The system verifies that the MFA setup or code belongs to the account of the logged in user. *	○	○	○	○	○
A verification or backup code can be used only with the account for which it was issued. *	○	○	○	○	○
MFA and backup codes can only be set up through the bank's own pages, not through hidden requests from another website. *	○	○	○	○	○

A02:2025 *

	1	2	3	4	5
Secret keys, one-time codes, backup codes, and login tokens never appear in logs, links, or error pages. *	○	○	○	○	○
The site uses secure browser settings, such as secure cookies and protections against framing or reuse by other sites. *	○	○	○	○	○
The app only accepts requests from trusted sites, has no default passwords, and hides technical error details. *	○	○	○	○	○

A04:2025 *

	1	2	3	4	5
The website always uses HTTPS with a secure, up-to-date connection. *	○	○	○	○	○

	1	2	3	4	5
The system securely generates and protects MFA secrets and backup codes. *	○	○	○	○	○
Login tokens and secret codes are not stored in the phone browser where they could be accessed. *	○	○	○	○	○

A05:2025 *

	1	2	3	4	5
The app sanitizes user input, including emails, phone numbers, and codes, before using it. *	○	○	○	○	○
Any links provided by the application keep users within the bank's own site. *	○	○	○	○	○
User text is safely displayed and cannot run hidden scripts or code. *	○	○	○	○	○

A07:2025 *

	1	2	3	4	5
The system blocks further attempts by the user after several incorrect codes. *	○	○	○	○	○
The application does not reveal whether an email address or account exists. *	○	○	○	○	○
Each verification or backup code is random, hard to guess, one-time, and expires quickly. *	○	○	○	○	○

User Story II
Case III: Detailed Inclusivity Specification and Same Security Criteria

The scenario is enhanced with an explicit description of dyslexia-related challenges and concrete inclusivity requirements, in addition to everything specified above.
Description of the Condition: People with dyslexia can find dense text, long character strings, and time-pressured reading difficult, and may process written information more slowly. The enrolment and verification flow must minimise reading load, avoid requiring manual transcription of long codes, and never impose reading-based time limits. Support comprehension through plain language, generous

spacing, and pairing text with icons.

Additional Requirements:

- Use a clear, legible, dyslexia-friendly typeface with adequate letter and line spacing (legible at mobile viewport sizes); avoid italics and all-caps for instructions.
- Keep instructions short and in plain language; avoid dense paragraphs and jargon; show a short example of any expected input, such as email or code format.
- Keep the interface free of moving, flashing, or auto-updating elements and visual clutter; make the current step and the primary action visually prominent so the user can find what to do at a glance.
- Offer copy-to-clipboard and QR-code options, and support browser autofill and password managers, so the user never has to manually transcribe secrets or long codes.
- Present one clear primary action per screen, minimise simultaneous choices, and after each action confirm plainly what happened and what the next step is.
- Keep layout, wording, and step order consistent and predictable throughout; make brief help or hints easy to find at every step; and let the user retry any step, or reveal, hide and re-request codes, without penalty.
- Do not impose time limits on reading steps; allow generous time to enter codes.
- Provide clear, specific error messages that state the problem and the fix without blaming the user.

Please access the code here: https://github.com/LLM4Code-inclusivitysecurity/securityevaluation/blob/main/story2_mfa_enrolment_dyslexia__case3_detailed_guidance.ts

Security Evaluation criteria

Scale (1-5)
1: Strongly disagree, 2: Disagree, 3: Neutral, 4: Agree, 5: Strongly Agree

A01:2025 *

	1	2	3	4	5
The system verifies that the MFA setup or code belongs to the account of the logged in user. *	○	○	○	○	○
A verification or backup code can be used only with the account for which it was issued. *	○	○	○	○	○
MFA and backup codes can only be set up through the bank's own pages, not through hidden requests from another website. *	○	○	○	○	○

A02:2025 *

	1	2	3	4	5
Secret keys, one-time codes, backup codes, and login tokens never appear in logs, links, or error pages. *	○	○	○	○	○
The site uses secure browser settings, such as secure cookies and protections against framing or reuse by other sites. *	○	○	○	○	○
The app only accepts requests from trusted sites, has no default passwords, and hides technical error details. *	○	○	○	○	○

A04:2025 *

	1	2	3	4	5
The website always uses HTTPS with a secure, up-to-date connection. *	○	○	○	○	○
The system securely generates and protects MFA secrets and backup codes. *	○	○	○	○	○
Login tokens and secret codes are not stored in the phone browser where they could be accessed. *	○	○	○	○	○

A05:2025 *

	1	2	3	4	5
The app sanitizes user input, including emails, phone numbers, and codes, before using it. *	○	○	○	○	○
Any links provided by the application keep users within the bank's own site. *	○	○	○	○	○
User text is safely displayed and cannot run hidden scripts or code. *	○	○	○	○	○

A07:2025 *

	1	2	3	4	5
The system blocks further attempts by the user after several incorrect codes. *	○	○	○	○	○
The application does not reveal whether an email address or account exists. *	○	○	○	○	○
Each verification or backup code is random, hard to guess, one-time, and expires quickly. *	○	○	○	○	○